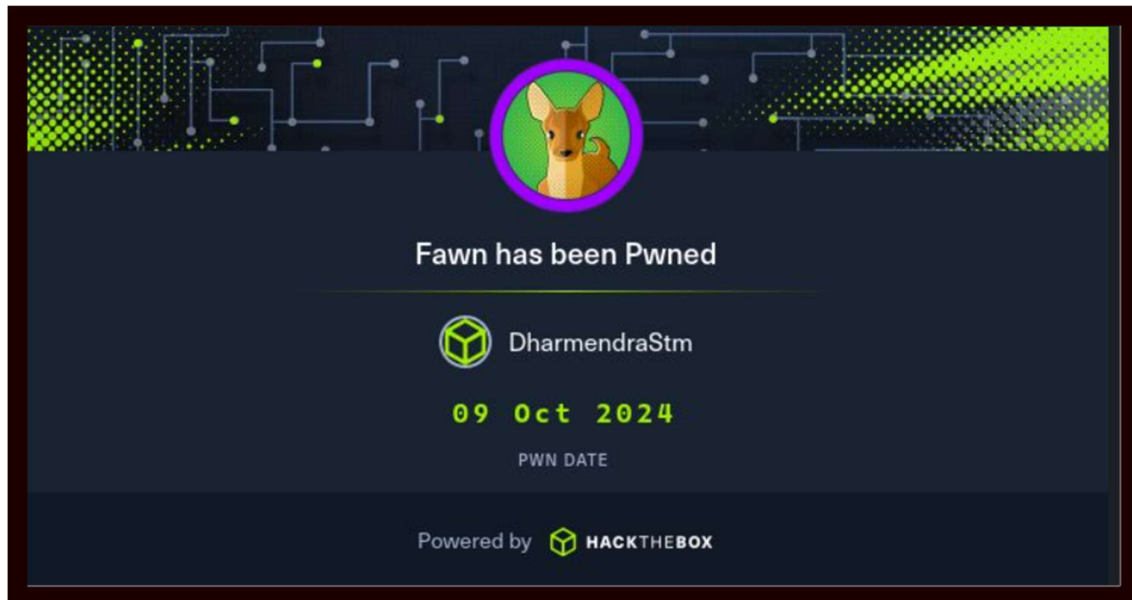


Hello everyone!

In this walkthrough, we'll solve the Fawn CTF room on HackTheBox by performing enumeration.



Tools:

1. Nmap
2. FTP

Description

The File Transfer Protocol (FTP) is widely used for transferring files between clients and servers, but it can pose significant security risks if not properly configured. Misconfigured FTP services may allow employees to bypass security controls, leading to unauthorized data transfers. Unsecured FTP servers can expose sensitive log files containing network information, such as usernames and active services, which attackers can exploit for further attacks. To mitigate these risks, organizations should secure FTP configurations, enforce strong authentication, consider using secure alternatives like SFTP or FTPS, and regularly audit and monitor FTP activities to protect sensitive data and maintain network integrity.

Enumeration

Enumeration is the process of extracting detailed information about a system, service, or network to identify vulnerabilities or gather intelligence for further exploitation. It typically follows initial scanning and involves actively probing the target to gather specific data.

Analysis

Step:-1 This nmap command is to run a scan on the 10.129.54.34 IP address and includes the following options:

```
sudo nmap -sV 10.129.54.34
```

-sV: Do service version scanning, which will reveal which services and their versions are running on which ports.

-sC and -sV switches will be employed in order to force default script usage (albeit intrusive) and advanced version detection for services identified on any of the open ports

```
(hacker@kali) ~$ sudo nmap -sC -sV 10.129.72.101
[sudo] password for hacker:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-09 21:21 IST
Nmap scan report for 10.129.72.101
Host is up (2.3s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r-- 1 0      0      32 Jun 04 2021 flag.txt
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:10.10.16.10
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 3
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.00 seconds
```

Step:-2 The command `sudo apt install ftp -y` is used in Debian-based Linux distributions (like Ubuntu) to install the FTP client package.

sudo: This command allows a permitted user to execute a command as the superuser or another user, as specified by the security policy. It's often required for administrative tasks like installing software.

apt: This stands for Advanced Package Tool, which is a package management system used to handle the installation, upgrading, and removal of software packages on Debian-based systems.

install: This option tells apt that you want to install a package.

ftp: This is the name of the package you want to install. In this case, it's the FTP client, which allows you to connect to FTP servers to upload and download files.

-y: This option automatically answers "yes" to any prompts during the installation process, allowing the installation to proceed without requiring further user input.

```
(hacker@kali) ~$ sudo apt install ftp -y
ftp is already the newest version (20230507-2).
The following packages were automatically installed and are no longer required:
 fonts-liberation2  libgail-common  libgtk2.0-0t64  libndctl6  libroc0.3  python3-hatch-vcs  rwho
 hydra-gtk  libgail18t64  libgtk2.0-bin  libplacebo338  libsvtav1enc1d1  python3-hatchling  rwhod
 ibverbs-providers  libgeos3.12.1t64  libgtk2.0-common  libplist3  libu2f-udev  python3-mistune0  samba-ad-provision
 libassuan0  libgeos3.12.2  libibverbs1  libpmem1  libusbmuxd6  python3-pathspect  samba-dsdb-modules
 libavfilter9  libgfpapi0  libimobiledevice6  libpostproc57  libx265-199  python3-pendulum  python3-pytdzdata
 libboost-iostreams1.83.0  libgfrpc0  libiniparser1  librados2  linux-image-6.6.15-amd64  python3-pluggy  python3-setuptools-scm
 libboost-thread1.83.0  libgfxdr0  libjsoncpp25  librav1e0  openjdk-17-jre  python3-pytdzdata  python3-trove-classifiers
 libcephfs2  libglusterfs0  libjxl0.7  librdmacm1t64  openjdk-17-jre-headless  python3-setuptools-scm  python3-trove-classifiers
 libdaxctl1  libgspell-1-2  libmfx1  libre2-10  python3-diskcache  python3-trove-classifiers

Use 'sudo apt autoremove' to remove them.

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 244
```

Step:-3 The command `ftp 10.129.72.101` is used to initiate an FTP (File Transfer Protocol) session with the server at the IP address 10.129.72.101

The `get` command in FTP is used to download a file from the remote FTP server to your local machine.

```
(hacker@kali)-[~]
└─$ ftp 10.129.72.101
Connected to 10.129.72.101.
220 (vsFTPD 3.0.3)
Name (10.129.72.101:hacker): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||9946|)
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 32 Jun 04 2021 flag.txt
226 Directory send OK.
ftp> get flag.txt
local: flag.txt remote: flag.txt
229 Entering Extended Passive Mode (|||36858|)
150 Opening BINARY mode data connection for flag.txt (32 bytes).
100% |*****| 32 0.07 KiB/s 00:00 ETA
226 Transfer complete.
32 bytes received in 00:01 (0.02 KiB/s)
ftp> cat flag.txt
?Invalid command.
ftp>
zsh: suspended ftp 10.129.72.101
```

Step:-4 The `ls` command in FTP is used to list the files and directories in the current working directory on the remote FTP server.

The `cat` command in Linux/Unix is used to display the contents of a file

```
(hacker@kali)-[~]
└─$ ls
CVE-2024-21413-Microsoft-Outlook-Remote-Code-Execution-Vulnerability Music Templates pentestlab
'DOM XSS in jQuery selector sink using a hashchange event.pdf' Pictures Videos pspy64s
Desktop Portfolio backup-OpenWrt-2023-07-26.tar rev.sh
Documents ProjectGreatMigration.pdf employees_wellness.pdf tickets.db
Downloads ProjectOpenWRT.pdf etc
MigrateOpenWrt.txt Public flag.txt

(hacker@kali)-[~]
└─$ cat flag.txt
035db21c881520061c53e0536e44f815
```

Finally, the flags have been identified

Task 1

What does the 3-letter acronym FTP stand for?

file transfer protocol

Task 2

Which port does the FTP service listen on usually?

21

Task 3

FTP sends data in the clear, without any encryption. What acronym is used for a later protocol designed to provide similar functionality to FTP but securely, as an extension of the SSH protocol?

sftp

Task 4

What is the command we can use to send an ICMP echo request to test our connection to the target?

ping

Task 5

From your scans, what version is FTP running on the target?

vsftpd 3.0.3

Task 6

From your scans, what OS type is running on the target?

unix

Task 7

What is the command we need to run in order to display the 'ftp' client help menu?

ftp -h

Task 8

What is username that is used over FTP when you want to log in without having an account?

Anonymous

Task 9

What is the response code we get for the FTP message 'Login successful'?

230

Task 10

There are a couple of commands we can use to list the files and directories available on the FTP server. One is `dir`. What is the other that is a common way to list files on a Linux system.

`ls`

Task 11

What is the command used to download the file we found on the FTP server?

`get`

Submit Flag

Submit root flag

035db21c881520061c53e0536e44f815

Thank you for your visit